

Escuela Superior Politécnica de Chimborazo
Facultad de Informática y Electrónica
Ingeniería de Software



Requisitos de seguridad según modelado de amenazas

Nombre:

Liliana Berzabe Paguay Carrillo – 7425

Kevin Gerardo Quiligana Vivas – 7462

Docente:

Ing. Isaac Torres

Asignatura:

Seguridad Informática

Periodo Académico Ordinario:

Octavo

Paralelo:

1

Riobamba, 27 de mayo del 2026

REQUISITOS FUNCIONALES DE SEGURIDAD (FSR)

Título: Desarrollo de un sistema web con un asistente inteligente para la gestión y seguimiento de los procesos del CEISH ESPOCH.

Contexto del proyecto: El proyecto consiste en el desarrollo de un sistema web integral para el Centro de Educación e Investigación en Salud (CEISH) de la ESPOCH, diseñado para digitalizar, gestionar y realizar el seguimiento en tiempo real de sus procesos académicos, administrativos y de investigación. La plataforma incorporará un asistente inteligente basado en IA que guiará a los usuarios, automatizará consultas, optimizará flujos de trabajo y proporcionará reportes dinámicos, facilitando la interacción entre estudiantes, docentes, investigadores y personal administrativo. Dado que el sistema centralizará datos personales, credenciales de acceso, documentos institucionales y registros de procesos críticos, su arquitectura exige garantizar la confidencialidad, integridad y trazabilidad de la información, lo que fundamenta la aplicación rigurosa de un levantamiento de requisitos de seguridad desde la fase de diseño (Shift Left) y alineado con buenas prácticas de ingeniería de software.

Metodología: Modelado de Amenazas (Threat Modeling) | Enfoque Shift Left

Definición Aplicada: "Los FSR definen QUÉ debe hacer el sistema para ser seguro. Son características, funciones o acciones explícitas que pueden señalarse, probarse y verificarse con un 'check'. Son los 'verbos' de la seguridad."

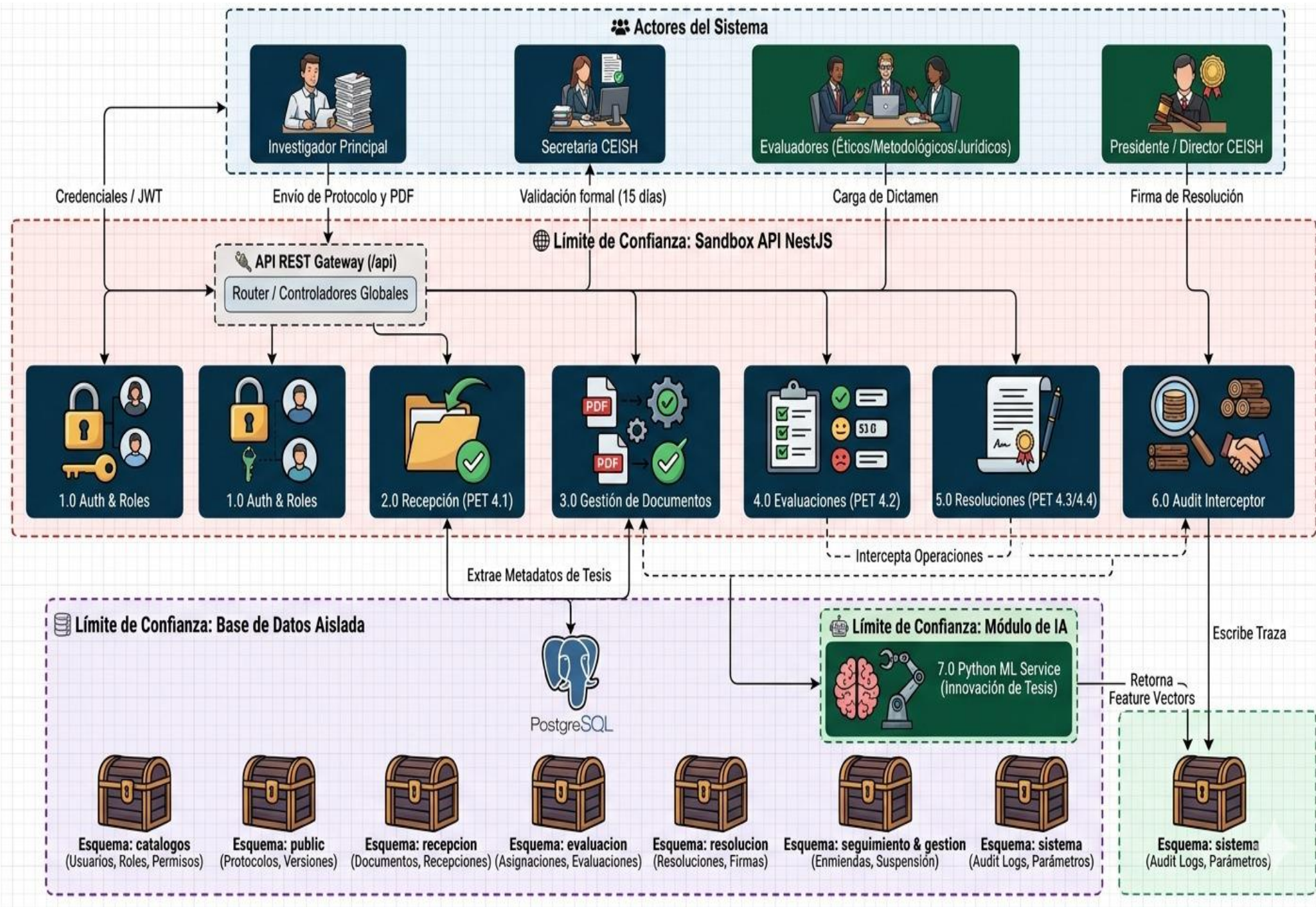
PASO 1: DESCOMPOSICIÓN DE LA APLICACIÓN CEISH-ESPOCH (DFD CONTEXTUAL)

No se puede defender lo que no se entiende. Se representa el sistema mediante un Diagrama de Flujo de Datos para identificar componentes y límites de confianza.

Componente	Descripción en CEISH-ESPOCH
Actores Externos	Investigador ESPOCH (interno/externo), Secretaria del CEISH, Presidenta del CEISH, Evaluador asignado, API del Ministerio de Salud Pública (reportes), API de correo institucional ESPOL/ESPOCH

Procesos (Backend NestJS)	- API de Autenticación y Gestión de Sesiones, Módulo de Recepción y Validación Documental de Protocolos, Módulo de Asignación de Evaluadores con balanceo de carga, Módulo de Evaluación Ética Digital con formularios PET 2023, Módulo de Emisión de Resoluciones con asistente inteligente, Módulo de Notificaciones Automatizadas y Alertas Escalonadas, Módulo de Generación de Reportes MSP (PDF/Excel), Módulo de Auditoría y Trazabilidad
Almacenes de Datos (PostgreSQL 15+)	BD_Usuarios (credenciales, roles, perfiles, estado), BD_Protocolos (metadatos, documentos adjuntos, estado del flujo PET), BD_Evaluaciones (dictámenes, criterios bioéticos, observaciones), BD_Resoluciones (resoluciones oficiales, firmas digitales, historial), BD_Auditoría (logs inmutables de todas las acciones críticas), BD_AsistenteIA (prompts, respuestas, contexto de interacción)
Flujos de Datos	Investigador → Frontend Angular → API REST NestJS → Lógica de negocio → PostgreSQL → Respuesta cifrada → Frontend → Investigador; Secretaria/Presidenta/Evaluador → Dashboard Angular → API → Validación PET 2023 → BD → Notificación automática → Correo institucional
Límites de Confianza	1. Internet ↔ API REST NestJS (zona pública → zona controlada con autenticación JWT) 2. API REST ↔ PostgreSQL (zona aplicación → zona persistencia con conexión SSL/TLS) 3. Sistema ↔ API Externa MSP (zona institucional → zona regulatoria con autenticación mutua) 4. Asistente Inteligente ↔ LLM externo (zona interna → zona de procesamiento IA con anonimización de datos sensibles)

DIAGRAMA DE FLUJO DE DATOS



PASO 2: IDENTIFICACIÓN DE AMENAZAS

Se "camina" por el DFD preguntando: "¿Cómo puede un atacante romper esto?" usando la mnemotecnia de Microsoft.

Letra STRIDE	Pregunta aplicada a CEISH-ESPOCH	Componente/Flujo Afectado	¿Viable?
Spoofing (Suplantación)	¿Puede un atacante suplantar la identidad de un investigador, evaluador o secretaria para enviar protocolos falsos, emitir resoluciones no autorizadas o alterar dictámenes?	API de Autenticación, Gestor de Sesiones JWT, Módulo de Emisión de Resoluciones	Sí
Tampering (Alteración)	¿Puede un atacante modificar documentos adjuntos de protocolos, dictámenes de evaluadores, resoluciones oficiales o registros de auditoría en tránsito o en reposo?	Flujos API↔PostgreSQL, Formularios de carga de documentos, BD_Protocolos, BD_Resoluciones	Sí
Repudiation (No Repudio)	¿Puede un evaluador, secretaria o presidenta negar haber emitido un dictamen, validado un documento o aprobado una resolución, sin que el sistema pueda demostrar lo contrario?	Módulo de Evaluación Ética, Módulo de Emisión de Resoluciones, BD_Auditoría	Sí
Information Disclosure (Divulgación)	¿Puede un investigador acceder a protocolos de otros investigadores, a dictámenes de evaluadores no asignados, a datos personales de participantes de estudios o a resoluciones no publicadas?	Endpoints de consulta de protocolos, BD_Protocolos, BD_Evaluaciones, Dashboard de reportes	Sí

Denial of Service (Denegación)	¿Puede un atacante saturar el endpoint de recepción de protocolos o el módulo de generación de reportes MSP para impedir la recepción de nuevos protocolos o la entrega de informes regulatorios en plazos críticos (48h para eventos adversos)?	API REST NestJS, Módulo de Reportes MSP, Conexión a PostgreSQL	Mitigado con NFSR
Elevation of Privilege (Elevación)	¿Puede un investigador con rol "Basic" acceder a funciones de secretaria (validar documentos), evaluador (emitir dictámenes) o presidenta (emitir resoluciones oficiales)?	Middleware de autorización NestJS, Control de acceso basado en roles (RBAC), Endpoints administrativos	Sí

PASO 3: LISTADO DE FSR – SISTEMA CEISH-ESPOCH (VERBOS DE SEGURIDAD)

Cada amenaza identificada se neutraliza con una acción explícita, verificable y asignada a un componente específico.

ID.FSR	Requisito Funcional de Seguridad (ACCIÓN)	Amenaza STRIDE	Componente NestJS/Angular	Prioridad
FSR-01	El sistema debe validar las credenciales de todos los usuarios (investigador, secretaria, evaluador, presidenta) mediante autenticación JWT con refresh token antes de conceder acceso a cualquier módulo.	Spoofing	AuthService, JwtStrategy, AuthGuard	Crítico

FSR-02	El sistema debe verificar el rol y permisos del usuario en cada petición a endpoints que manejen datos sensibles (validar protocolo, emitir dictamen, generar resolución) mediante guards de autorización.	Elevation of Privilege	RolesGuard, PoliciesGuard, Decorators @Roles()	Crítico
FSR-03	El sistema debe registrar en la tabla auditoria todas las acciones críticas: creación/modificación/eliminación de protocolos, emisión de dictámenes, generación de resoluciones, cambios de estado PET, con user_id, timestamp UTC, IP, acción y valores antes/después.	Repudiation	AuditLogInterceptor, EntitySubscriber, Tabla auditoria	Medio
FSR-04	El sistema debe cifrar los campos sensibles (contraseñas, datos personales de participantes, consentimientos informados) antes de almacenarlos en PostgreSQL, y debe enmascarar dichos campos en respuestas API a roles no autorizados.	Information Disclosure	CryptoService (Argon2id/bcrypt), Select en queries, DTOs con class-transformer	Alto
FSR-05	El sistema debe validar y sanitizar todas las entradas de usuario provenientes de formularios Angular y APIs externas (MSP) contra esquemas Zod/Joi antes de	Tampering	ValidationPipe, Zod schemas, Class-validator	Alto

	cualquier procesamiento o consulta a PostgreSQL.			
FSR-06	El sistema debe cerrar automáticamente la sesión del usuario tras 15 minutos de inactividad configurable, invalidando el token JWT y requiriendo re-autenticación para acceder a módulos críticos.	Spoofing / Session Hijacking	JwtService con expiresIn, RefreshTokenService, Interceptor de inactividad	Bajo
FSR-07	El sistema debe generar y enviar un token de un solo uso (OTP) vía correo institucional ESPOL/ESPOCH para operaciones de recuperación de cuenta, cambio de contraseña o emisión de resoluciones oficiales.	Spoofing	OtpService, MailerModule, Template de correo seguro	Alto
FSR-08	El sistema debe anonimizar automáticamente los datos personales de participantes de investigación antes de enviar cualquier contexto al asistente inteligente externo, garantizando que el LLM nunca reciba información identificable.	Information Disclosure	AnonymizationService, Middleware de pre-procesamiento para IA	Alto
FSR-09	El sistema debe generar reportes regulatorios para el Ministerio de Salud Pública (formato PDF/Excel) con firma digital y sello de tiempo, garantizando integridad y no repudio en la entrega oficial.	Repudiation	ReportService, PDFKit con firma digital, Timestamping API	Alto

CASOS DE ABUSO (REQUISITOS NEGATIVOS – FSR)

Definen lo que el sistema NO debe permitir. Son FSR con lógica inversa, como indicó el ingeniero en clase.

ID-ABU	Caso de Abuso (Requisito Negativo)	Amenaza Prevenida
ABU-01	El sistema NO debe permitir que un investigador acceda a protocolos, dictámenes o resoluciones de otros investigadores alterando el ID en la URL o payload (prevención de vulnerabilidad IDOR).	Information Disclosure / Elevation of Privilege
ABU-02	El sistema NO debe revelar en mensajes de error si un correo institucional está registrado, si la contraseña es incorrecta o si un protocolo existe, devolviendo siempre respuestas genéricas "Credenciales o recurso no válidos".	Information Disclosure (Enumeración de usuarios/recursos)
ABU-03	El sistema NO debe ejecutar consultas SQL concatenadas con entradas de usuario; todas las consultas a PostgreSQL deben usar TypeORM con parámetros vinculados o QueryBuilder con sanitización.	Tampering (SQL Injection)
ABU-04	El sistema NO debe permitir inicio de sesión simultáneo con las mismas credenciales desde IPs geográficamente distantes (ej. Ecuador y otro país) sin verificación adicional mediante OTP o notificación de seguridad.	Spoofing / Account Takeover
ABU-05	El sistema NO debe almacenar en logs, respuestas API o caché ningún dato personal de participantes de investigación, consentimientos informados sin cifrar, o claves de API externas.	Information Disclosure (Fuga en logs/metadatos)
ABU-06	El sistema NO debe permitir que el asistente inteligente externo acceda directamente a la base de datos PostgreSQL; toda interacción debe pasar por un servicio intermediario que anonimice, filtre y audite el contexto enviado.	Information Disclosure / Tampering vía IA

PASO 4: PRIORIZACIÓN DE FSR (ESCALA DE IMPACTO AL NEGOCIO CEISH-ESPOCH)

Prioridad	Justificación Técnica y Regulatoria (SEGÚN LÓGICA DE CLASE Y PET 2023)	FSR Priorizados
CRÍTICO	Amenaza más probable y fácil de explotar. Si un investigador actúa como evaluador o presidenta, se compromete la integridad ética de las resoluciones, pudiendo generar llamados de atención del MSP o revocatoria del acuerdo ministerial. Es el clásico Broken Access Control (OWASP #1).	FSR-01, FSR-02
ALTO	Impacto directo en confidencialidad de datos sensibles (Ley Orgánica de Protección de Datos Personales) o integridad de documentos regulatorios. Una fuga de datos de participantes o alteración de resoluciones genera daño catastrófico legal y reputacional para la ESPOCH.	FSR-04, FSR-05, FSR-07, FSR-08, FSR-09
MEDIO	Vital para trazabilidad y auditoría forense ante observaciones del MSP o investigaciones internas, pero es un control de detección post-incidente, no de prevención directa.	FSR-03
BAJO	Mejora la postura de seguridad operativa, pero depende de políticas de tiempo y no bloquea vectores activos de ataque críticos para el cumplimiento regulatorio.	FSR-06

INTEGRACIÓN EN SPRINTS SCRUM

No se crea una metodología aparte. Los FSR se mezclan con los requisitos funcionales del sistema en el backlog priorizado:

- Sprint 1 (Gestión de Usuarios): RF-Registro de usuarios + FSR-01, FSR-04, ABU-02 → Historias: "Como secretaria, quiero registrar evaluadores con rol validado" + "El sistema debe hashear contraseñas con Argon2id" + "El login no debe revelar si el correo existe".
- Sprint 2 (Recepción de Protocolos): RF-Carga de documentos + FSR-02, FSR-05, ABU-01, ABU-03 → Historias: "Como investigador, quiero subir documentos del

protocolo" + "El sistema debe validar que solo el propietario acceda a su protocolo"
+ "Todas las entradas deben sanitizarse contra inyecciones".

- Sprint 3 (Evaluación y Resoluciones): RF-Dictámenes y resoluciones + FSR-03, FSR-07, FSR-09, ABU-04 → Historias: "Como evaluador, quiero emitir dictamen con firma digital" + "El sistema debe registrar en auditoría cada acción" + "Se debe enviar OTP para confirmar resolución oficial".
- Sprint 4 (Asistente Inteligente y Reportes): RF-Asistente IA + FSR-08, ABU-05, ABU-06 → Historias: "Como secretaria, quiero que el asistente redacte comunicados" + "El sistema debe anonimizar datos antes de enviar a IA" + "Ningún dato sensible debe quedar en logs del asistente".

Esto garantiza el principio Shift Left: seguridad desde el diseño, no parches al final. Cada FSR tiene criterios de aceptación verificables en pruebas unitarias (Jest) y de aceptación (Cypress).

REQUISITOS NO FUNCIONALES DE SEGURIDAD (NFSR)

Título: Desarrollo de un sistema web con un asistente inteligente para la gestión y seguimiento de los procesos del CEISH ESPOCH.

Metodología: Modelado de Amenazas (Threat Modeling) | Enfoque Shift Left

Definición Aplicada: Los NFSR definen CÓMO debe ser el sistema en términos de seguridad, o las cualidades, restricciones y estándares que debe cumplir. Son los 'adjetivos' o 'adverbios' de la seguridad. Definen el 'qué tan bien' se ejecutan los FSR.

RELACIÓN FSR ↔ NFSR

FSR (QUÉ / Verbo)	NFSR (CÓMO / Adjetivo o Restricción)
"El sistema debe cifrar contraseñas"	"El cifrado debe usar Argon2id con salt automático y parámetros que resistan fuerza bruta (>100ms/ intento). MD5 o SHA1 sin salt son técnicamente 'cifrar', pero son obsoletos e inseguros según OWASP."
"El sistema debe verificar el rol en cada petición"	"La validación debe ejecutarse en el backend NestJS para cada endpoint, usando guards con políticas RBAC, nunca confiar en validaciones solo en frontend Angular."
"El sistema debe registrar logs de auditoría"	"Los logs deben ser inmutables: almacenarse en tabla auditoria con hash encadenado (SHA-256) por registro, acceso solo lectura para operadores, y retención mínima de 7 años según PET 2023."
"El sistema debe anonimizar datos para el asistente IA"	"La anonimización debe eliminar todos los identificadores directos e indirectos (nombres, cédulas, instituciones, fechas exactas) usando técnicas de k-anonimidad, y registrar en auditoría cada contexto enviado al LLM externo."

Ningún FSR se implementa sin su NFSR correspondiente. El NFSR cierra la brecha entre "cumplir el requisito" y "cumplirlo con ingeniería de software profesional, auditable y alineado a normativa".

PASO 3: LISTADO DE NFSR – SISTEMA CEISH-ESPOCH (CALIDADES Y RESTRICCIONES)

Cada NFSR es una restricción técnica medible, alineada a estándares de la industria y normativa ecuatoriana.

ID-NFSR	Requisito No Funcional (CUALIDAD/ RESTRICCIÓN)	FSR Asociado	Estándar/Referencia	Métrica de Verificación
NFSR-01	El hash de contraseñas debe implementarse con Argon2id (o bcrypt como fallback), con salt automático, memoria ≥ 64 MB, iteraciones ≥ 3 , y tiempo objetivo > 100 ms por intento para resistir ataques de fuerza bruta.	FSR-01, FSR-04	OWASP Password Storage Cheat Sheet, NIST SP 800-63B	Auditoría de código: función usa @node-rs/argon2 con parámetros seguros; prueba de fuerza bruta simula > 100 ms/intento
NFSR-02	La validación de roles y permisos debe ejecutarse en el backend NestJS para cada petición a endpoints sensibles, usando guards con políticas RBAC basadas en roles (investigador, evaluador, secretaria, presidenta) y recursos (protocolo_id), nunca confiar en validaciones solo en frontend Angular.	FSR-02	OWASP ASVS V4.0 - V4.1, ISO 27001 A.9.1.2	Test de penetración: petición con rol investigador a endpoint /api/resoluciones → HTTP 403 consistente; revisión de código: todos los controllers usan @Roles() y PoliciesGuard
NFSR-03	Los logs de auditoría deben ser inmutables y trazables: almacenarse en tabla auditoria con hash SHA-256 encadenado por registro (cada hash incluye el	FSR-03, FSR-09	ISO 27001 A.12.4.1, NIST 800-92, PET CEISH-ESPOCH 2023	Intento de UPDATE/DELETE en tabla auditoria → rechazado por trigger; verificación de cadena

	hash anterior), acceso solo lectura para operadores, retención mínima de 7 años según PET 2023, y exportación firmada digitalmente para entregas al MSP.			de hashes con script independiente; prueba de retención: datos de hace 7 años accesibles
NFSR-04	Los datos sensibles en tránsito deben protegerse exclusivamente con TLS 1.3 (sin soporte para versiones anteriores). En reposo, los campos sensibles (contraseñas, datos personales, consentimientos) deben cifrarse con AES-256-GCM o equivalente aprobado por NIST, con gestión de claves mediante variables de entorno cifradas o AWS KMS.	FSR-04, FSR-08	PCI-DSS Req. 4.1, NIST SP 800-38D, Ley Orgánica de Protección de Datos Personales Art. 17	Inspección de tráfico con Wireshark: solo TLS 1.3; inspección de BD PostgreSQL: campos sensibles ilegibles sin clave; prueba de fuga: respuesta API a rol no autorizado no incluye datos cifrados
NFSR-05	Todas las entradas de usuario deben validarse contra esquemas estrictos antes de cualquier procesamiento, usando Zod o Class-validator con reglas específicas (email institucional @epoch.edu.ec/@espol.edu.ec, formatos de cédula ecuatoriana, tipos de archivo permitidos para documentos), rechazando payloads malformados con código HTTP 400 y mensaje genérico.	FSR-05, ABU-03	OWASP Input Validation Cheat Sheet, PET 2023 - Requisitos documentales	Escaneo SAST con SonarQube: 0 vulnerabilidades de inyección (SQLi/XSS/NoSQLi); prueba de fuzzing: entradas maliciosas rechazadas con 400 genérico

NFSR-06	Los tokens JWT de sesión deben tener expiración máxima de 15 minutos para acceso normal, y 5 minutos para operaciones sensibles (emisión de resoluciones, cambios de configuración). El refresh token debe rotarse en cada uso, almacenarse cifrado en BD y invalidarse tras logout o cambio de contraseña.	FSR-06, FSR-07	OWASP Session Management Cheat Sheet, NIST SP 800-63B	Prueba de token expirado: acceso denegado; prueba de reuso de refresh token: invalidación automática; auditoría de código: JwtService con expiresIn configurado
NFSR-07	Los mensajes de error visibles al usuario no deben revelar detalles internos del sistema, existencia de usuarios, tipo de fallo de autenticación o estructura de la base de datos, devolviendo siempre respuestas genéricas "Credenciales o recurso no válidos" con código HTTP 401/403/404 según corresponda.	ABU-02	OWASP Error Handling Guidelines, PET 2023 - Transparencia controlada	Prueba de login con correo no registrado vs. contraseña incorrecta → mismo mensaje genérico; revisión de logs: errores internos no expuestos en respuestas API
NFSR-08	La anonimización de datos para el asistente inteligente debe eliminar todos los identificadores directos (nombres, cédulas, correos, instituciones) e indirectos (fechas exactas, ubicaciones específicas, combinaciones únicas) usando técnicas de k-anonimidad con $k \geq 5$, y registrar en auditoría cada	FSR-08, ABU-05, ABU-06	Ley Orgánica de Protección de Datos Personales Art. 17, GDPR Art. 25 (Privacy by Design)	Prueba de re-identificación: intento de recuperar datos originales desde contexto anonimizado → fallido; auditoría: cada llamada a IA registrada con hash y timestamp

	contexto enviado al LLM externo con hash del original para trazabilidad.			
NFSR-09	El sistema debe implementar rate limiting configurable por endpoint: máximo 10 peticiones/minuto para login, 30 para consulta de protocolos, 5 para generación de reportes MSP, con bloqueo temporal de IP tras 5 intentos fallidos consecutivos y notificación a secretaria.	(DoS)	OWASP API Security Top 10 #4:2023, PET 2023 - Disponibilidad del servicio	Prueba de carga con k6: bloqueo tras límite configurado, sin afectar usuarios legítimos; monitoreo: alertas enviadas a secretaria tras intentos sospechosos
NFSR-10	La conexión entre NestJS y PostgreSQL debe usar SSL/TLS obligatorio, con certificados válidos emitidos por autoridad de confianza de la ESPOCH, y las credenciales de base de datos deben gestionarse mediante variables de entorno cifradas o AWS Secrets Manager, nunca en código fuente.	FSR-04, FSR-05	ISO 27001 A.13.1.1, PET 2023 - Seguridad de la información	Inspección de configuración TypeORM: ssl: { rejectUnauthorized: true }; auditoría de repositorio: 0 credenciales en código; prueba de conexión sin SSL → rechazada

PASO 4: PRIORIZACIÓN DE NFSR

Prioridad	ID-NFSR	Justificación Técnica y Regulatoria	Acción Inmediata en Desarrollo
CRÍTICO	NFSR-02	Sin validación backend, el control de acceso es ilusorio. Un investigador que acceda a funciones de presidenta podría emitir resoluciones no autorizadas,	Implementar RolesGuard y PoliciesGuard en NestJS; revisar todos los controllers con @Roles(); pruebas de integración con roles cruzados

		generando incumplimiento del Acuerdo Ministerial MSP No. 00005-2022 y posible revocatoria del registro del CEISH-ESPOCH. Es la base arquitectónica de seguridad.	
CRÍTICO	NFSR-01	Un hash débil (MD5, SHA1) permite recuperación de contraseñas en minutos con herramientas como Hashcat. Argon2id es el estándar actual recomendado por OWASP para proteger credenciales de roles críticos (secretaria, presidenta) que acceden a datos sensibles.	Configurar @node-rs/argon2 con parámetros: memoryCost: 65536, timeCost: 3, parallelism: 1; pruebas de fuerza bruta simulada
ALTO	NFSR-04, NFSR-05, NFSR-08	Previenen fugas de datos personales (Ley Orgánica de Protección de Datos) e inyecciones que podrían corromper dictámenes o resoluciones. La anonimización para IA es crítica porque el LLM externo es un tercero no controlado por la ESPOCH.	Habilitar TLS 1.3 en PostgreSQL y NestJS; parametrizar todas las consultas con TypeORM; implementar AnonymizationService con reglas de k-anonimidad; pruebas de fuga con datos de prueba
MEDIO	NFSR-03, NFSR-09	Permiten auditoría forense ante observaciones del MSP y disponibilidad del servicio para cumplir plazos regulatorios (48h para eventos adversos). Son controles de contención y detección, esenciales pero no preventivos directos.	Implementar trigger de hash encadenado en tabla auditoria; configurar @nestjs/throttler con límites por endpoint; pruebas de retención y recuperación de logs

BAJO	NFSR-06, NFSR-07, NFSR-10	Mejoran experiencia de usuario y resiliencia operativa, pero no son críticos si los controles de acceso, cifrado y validación están sólidos. Son buenas prácticas que elevan la madurez de seguridad.	Configurar JwtService con expiresIn; implementar ExceptionFilter para errores genéricos; migrar credenciales a variables de entorno cifradas
------	---------------------------------	---	--

CUMPLIMIENTO DE ESTÁNDARES Y NORMATIVA ECUATORIANA

Estándar/Normativa	Ámbito en CEISH-ESPOCH	NFSR Relacionados
OWASP ASVS 4.0	Verificación técnica en desarrollo web/API institucional	NFSR-01, 02, 05, 06, 09
ISO 27001:2022	Gestión de seguridad de la información sensible del comité	NFSR-03, 04, 10
NIST SP 800-63B	Autenticación digital y gestión de identidad de usuarios del CEISH	NFSR-01, 06
Ley Orgánica de Protección de Datos Personales (Ecuador)	Protección de datos personales de participantes de investigación	NFSR-04, 08
Acuerdos Ministeriales MSP No. 00015-2021 y 00005-2022	Plazos regulatorios, trazabilidad y reporte de actividades del CEISH	NFSR-03, 09
PET CEISH-ESPOCH 2023	Procedimientos operativos, retención documental y auditoría interna	NFSR-03, 07, 09
OWASP Top 10 2021	Resistencia general del sistema frente a vectores de ataque conocidos	Todos (los NFSR definen el "qué tan bien" contra estos riesgos)

CONCLUSIÓN NFSR

Este documento define cómo y cuán bien debe ejecutarse cada Requisito Funcional de Seguridad del sistema CEISH-ESPOCH. Cada NFSR es una restricción técnica medible, alineada a estándares internacionales (OWASP, ISO, NIST) y normativa ecuatoriana (Ley de Protección de Datos, Acuerdos MSP, PET 2023), que garantiza que la implementación de los FSR sea robusta, auditable, profesional y sostenible a largo plazo. Como se enfatizó en clase: la diferencia entre un desarrollador empírico y un ingeniero de software es la aplicación metodológica de técnicas y estándares. Estos NFSR aseguran que el sistema CEISH-ESPOCH no solo "haga" lo que debe (FSR), sino que lo haga con la calidad, resistencia, trazabilidad y cumplimiento regulatorio exigidos por la ingeniería de software moderna y la responsabilidad ética de proteger a los participantes de investigación.